

Student Ransomware Playbook

A plain-language guide for college and university students. How to spot phishing, protect your accounts and coursework, and know what to do if something goes wrong.

Created by Joshua Gerstenfeld and Scott Jacques with support from the CrimRxiv Consortium. Open access. Code MIT-licensed; content CC BY 4.0. Live site: <https://crimconsortium.github.io/student-ransomware-playbook/>

Protect yourself (before anything goes wrong)

- Turn on multi-factor authentication (MFA) for your campus account, email, and any system holding your records.
- Use a password manager and a unique password for your campus identity. Never reuse it on other sites.
- Keep your laptop, phone, and browser updated. Install updates within 7 days of release.
- Back up your coursework to campus cloud storage (and a second copy where allowed). Don't rely on a single drive.
- Save the IT help desk and security team contact info in your phone before you need it.
- Complete any phishing or security training the campus offers — even short modules build real skill.
- Review your account recovery options (backup email, phone) so an attacker can't reset your password.

Phishing red flags

- Urgency: "Your account will be locked in 24 hours."
- A login link in the message — type your campus URL into the browser yourself.
- Sender domain close but not exact (e.g., support@my-college.edu.help).
- Unexpected attachments — zip files, OneNote files, HTML "invoices."
- Offers too good to be true: surprise scholarships, refunds, high-paying student jobs.
- MFA prompts you didn't trigger. Never approve a prompt you didn't start.

If something goes wrong

In the moment

- If a message, login page, or pop-up looks suspicious, stop. Do not click, do not enter credentials.
- If you already clicked or entered a password, change that password from a different device and report it now.
- If your device is acting strange (files renamed, ransom note, unexpected encryption), disconnect it from Wi-Fi and any cables, leave it powered on, and contact IT.
- Forward suspicious emails using the campus 'Report Phishing' button or as an attachment to the security team.
- Don't try to 'fix' a suspected infection yourself. Don't pay a ransom on a personal device — call IT.
- Follow official guidance from the campus emergency channel. Ignore unverified rumors on social media.

After the dust settles

- Change passwords for any account that may have been exposed and review login history.
- Re-enable backups and confirm your important files are still recoverable.
- Tell classmates and roommates what you saw — phishing campaigns usually target many students at once.
- Attend any post-incident briefings; they teach you the exact lure that worked so you can avoid the next one.

Quick checklist

- MFA is on for my campus email and student portal.
- I use a password manager (or at least a unique password for school accounts).
- My laptop and phone install updates automatically.
- I have at least one backup of my coursework outside the device I use daily.
- I know how to report a phishing email on my campus.
- The IT help desk number is saved in my phone.
- I've reviewed my account recovery email and phone in the last 6 months.

Practice scenarios

Ten short, realistic situations you can practice on the live site — each with branching decisions and feedback on every choice. Open the interactive version at crimconsortium.github.io/student-ransomware-playbook/scenarios.html and earn a printable Cyber-Smart Student certificate after all ten.

01. The 'IT Help Desk' email

At 11:47 PM, the night before a paper is due, you get an email titled 'ACTION REQUIRED: Your campus account will be deleted in 24 hours.' It says click the link to 'verify your identity' or lose access to your coursework. The sender address has your school's name in it, but the domain after the @ doesn't quite match your school.

02. The Canvas link that wasn't

Your TA shares 'a quick poll for Friday's class' in the course Discord. The link opens a page that looks like your school's Canvas login, but the URL in the address bar reads 'canvas-myschool-edu.app/auth'.

03. The dorm laptop ransom note

You walk into your dorm and your roommate's laptop is open on the desk. The screen shows a red ransom note demanding \$400 in Bitcoin to 'decrypt your files.' Your roommate isn't home. The laptop is plugged in via Ethernet to the dorm jack.

04. The 2 AM MFA prompts

At 2:11 AM your phone buzzes with an MFA push notification. 'Approve sign-in?' You ignore it. Two minutes later, another. By 2:20 AM you've had nine prompts in a row. You're not trying to sign in to anything.

05. The 'paid research assistant' DM

Someone DMs you on LinkedIn claiming to be a visiting professor in your department. They're 'urgently hiring a paid research assistant for remote work — \$40/hr, 10 hrs/week.' They ask for your personal email so they can send a contract, and request you Venmo \$75 for 'software setup' that they'll reimburse with your first paycheck.

06. 'Verify your FAFSA refund'

You get a text: '[University] Financial Aid: Your refund of \$1,432.18 is on hold. Verify your bank info within 12 hours to prevent reversal: [hxxps://fin-aid-portal-myschool.com](https://fin-aid-portal-myschool.com)'.

07. The club Google Drive looks weird

You're the secretary of a campus club. This morning, your shared Google Drive shows two folders missing, several files renamed to 'encrypted-by-...' style names, and a new 'share' to an external Gmail address you don't recognize. The club president is in class.

08. Stolen laptop at the library

You stepped away for two minutes to refill a water bottle. Your laptop is gone. It was unlocked. Your campus email, Canvas, and a draft of your thesis were open.

09. The roommate who wants 'just one login'

Your roommate asks if they can borrow your campus login to access the library's paid databases for an essay due tomorrow. They say theirs 'glitched out' and they don't want to wait for the help desk to open.

10. The unmarked USB stick

You find a USB stick on the desk in a group study room you just booked. No label, no name, no return-address sticker. You wonder if it's a classmate's lost drive.

FAQ

What even is ransomware, in plain terms?

Malicious software that locks up files (and often steals copies first) so someone can demand payment to unlock them or to not publish them. As a student, you mainly see the front door: phishing emails, fake login pages, and account takeovers that let attackers in.

Why should I care — isn't this an IT problem?

Your account is the easiest way in. Compromised student accounts have been used to attack faculty, raid scholarship funds, exfiltrate course rosters, and reset other passwords. A single careless click can affect your grades, financial aid, and roommates.

I think I clicked a phishing link. What now?

Stop using the device. From a different device (your phone is fine), change the password for the affected account, then call the campus IT help desk. Keep the original message — IT may need it. Speed matters more than embarrassment.

My laptop is showing a ransom note. What should I do?

Don't pay anything. Disconnect from Wi-Fi and unplug any cables, but leave the device powered on (forensics may need volatile memory). Call campus IT immediately. Don't try to 'fix' it yourself.

Is the campus going to discipline me if I report a mistake?

Most campuses have a non-punitive reporting culture for honest reports — they need the data to defend everyone. Check your campus policy, but the cost of not reporting is almost always worse than the cost of reporting.

Should I use a personal device for schoolwork?

Generally fine if it's up to date, has MFA on your campus account, and you don't pirate software on it. Some courses or programs (e.g., clinical, legal, research with sensitive data) require institution-managed devices — check your syllabus.

Is MFA actually worth the hassle?

Yes. Multi-factor authentication blocks almost all bulk credential-phishing. Phishing-resistant MFA (FIDO2 / passkeys / hardware keys like YubiKey) is even stronger. Enable it wherever your campus offers it.

Is public Wi-Fi at the coffee shop dangerous?

Less than it used to be — most sites and apps use HTTPS by default — but it's still a good idea to avoid logging into your campus account from networks you don't trust, and to use your campus VPN if your school provides one.

Can this site substitute for legal advice?

No. This is a plain-language educational summary. Specific obligations under FERPA, state breach laws, or your campus policies depend on your situation — talk to your IT help desk, dean

of students, or campus counsel.

Glossary

After-action review (AAR) — A structured, blameless review held after an incident to capture what happened, what worked, what didn't, and what to change. Produces a written report with tracked actions.

Backups (immutable / offline) — Copies of data that cannot be altered or deleted by a normal admin (immutable) or are physically disconnected (offline). Critical for ransomware recovery.

CISA — U.S. Cybersecurity and Infrastructure Security Agency. Publishes the #StopRansomware guide and maintains free resources for higher education.

Command and control (C2) — Infrastructure attackers use to communicate with malware on compromised systems. Blocking C2 helps stop ongoing attacks.

Containment — Steps that stop an attack from spreading further: isolating hosts, disabling accounts, revoking sessions, blocking outbound traffic.

Decryption key — The key needed to reverse ransomware encryption. May or may not be supplied by attackers after payment; sometimes published by law enforcement.

Detection — Identifying that an intrusion or attack is occurring or has occurred, ideally before damage is done.

Endpoint Detection and Response (EDR) — Software that monitors laptops, desktops, and servers for malicious behavior and supports investigation and response.

FERPA — Family Educational Rights and Privacy Act (U.S.). Governs the privacy of student education records and shapes notification obligations.

FIDO2 / WebAuthn — Phishing-resistant authentication standards. Hardware keys and platform authenticators (Touch ID, Face ID, Windows Hello) implement them.

Incident Commander — The single person responsible for directing the response during an incident, regardless of normal seniority.

Indicator of Compromise (IOC) — An observable artifact (file hash, IP, domain, behavior) that suggests a system has been attacked.

MFA / Multi-factor authentication — Requiring more than a password to sign in, typically a code or hardware key. Phishing-resistant MFA (FIDO2) defeats most credential phishing.

MFA fatigue — Attack where an attacker repeatedly triggers MFA prompts hoping the user approves one out of frustration.

NIST — U.S. National Institute of Standards and Technology. Publishes the Cybersecurity Framework and SP 800-61 for incident response.

Phishing — Deceptive messages (email, SMS, voice, web) that trick users into entering credentials, running malware, or approving fraudulent transactions.

Ransomware — Malware that encrypts files and/or steals data, then demands payment to restore access or to prevent publication.

RDP — Remote Desktop Protocol. Frequently abused by attackers when exposed to the internet without strong controls.

Segmentation — Dividing a network into zones so a compromise in one area can't spread freely to others.

Tabletop exercise — A facilitated discussion-based drill where leaders walk through their response to a hypothetical incident.

Third-party risk — Risk introduced by vendors, SaaS providers, and contractors. Recent higher-ed ransomware impact has been driven heavily by exploited third-party software.

Sources

CISA Secure Our World — Plain-language consumer guidance from the U.S. Cybersecurity & Infrastructure Security Agency on MFA, phishing, passwords, and updates.

<https://www.cisa.gov/secureourworld>

CISA #StopRansomware — U.S. CISA hub of ransomware guidance, including how to report an incident.

<https://www.cisa.gov/stopransomware>

National Cybersecurity Alliance — StaySafeOnline — General-public cybersecurity basics, including phishing, passwords, and account safety.

<https://staysafeonline.org/online-safety-privacy-basics/>

EDUCAUSE: Cybersecurity Awareness for College Students — Higher-ed-focused student safety tips from Purdue/EDUCAUSE.

<https://library.educause.edu/resources/2020/9/cybersecurity-awareness-for-college-students-7-things-to-do-now>

Federal Trade Commission — Identity Theft and Online Security — U.S. FTC guidance for individuals on online privacy, scams, and recovering from identity theft.

<https://consumer.ftc.gov/identity-theft-and-online-security/online-privacy-and-security>

FBI Internet Crime Complaint Center (IC3) — Where U.S. individuals and institutions can report cyber incidents to the FBI.

<https://www.ic3.gov/>

Higher Ed Dive: Ransomware in Education, H1 2025 — Reporting on the scale and trends of ransomware affecting colleges and schools.

<https://www.highereddive.com/news/ransomware-attacks-education-jump-23-percent-h1-2025/754011/>